MINI-PROJET · AUDIT ISO/IEC 2700x

Architecture de prévention et de détection Anti-DDoS open source

Nginx · Docker · CrowdSec · Prometheus · OpenSCAP
sur Red Hat Enterprise Linux

Réalisé par
Rayen Sliti

Encadrant
Mourad Melliti

TEK-UP University
Classe CII-5-J-SSIR-G
Année 2026-2027
Soutenance du 13 octobre 2026

PROBLÉMATIQUE

Question posée

Comment maintenir la disponibilité d’une application Web face à des requêtes excessives ou malveillantes, avec un hôte durci, journalisé, segmenté et aligné sur ISO/IEC 27001 ?

Périmètre : attaques applicatives et petits floods réseau, dans un laboratoire isolé.

PLAN

Déroulé de la présentation

1. **Architecture**
   Point d'entrée unique, segmentation

2. **Durcissement de l'hôte**
   SSH, pare-feu, noyau, intégrité

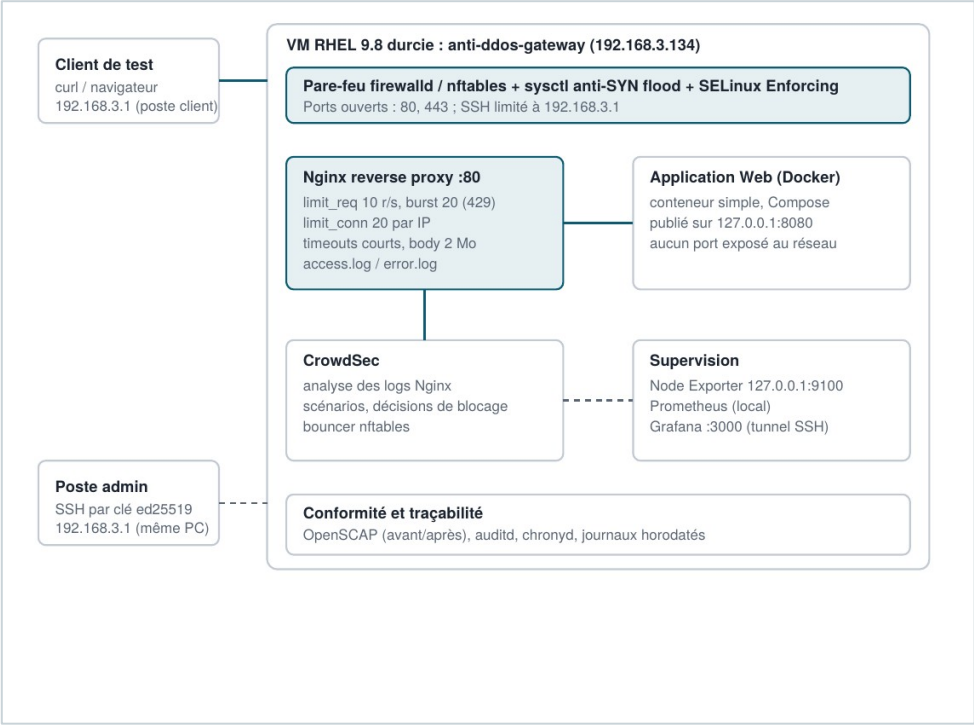
3. **Limitation du débit**
   Nginx — démonstration en direct

4. **Détection et blocage**
   CrowdSec — démonstration en direct

5. **Supervision et conformité**
   Grafana, OpenSCAP

6. **Bilan, limites et conclusion**
   Objectifs atteints, ce qui reste

Un point d’entrée unique



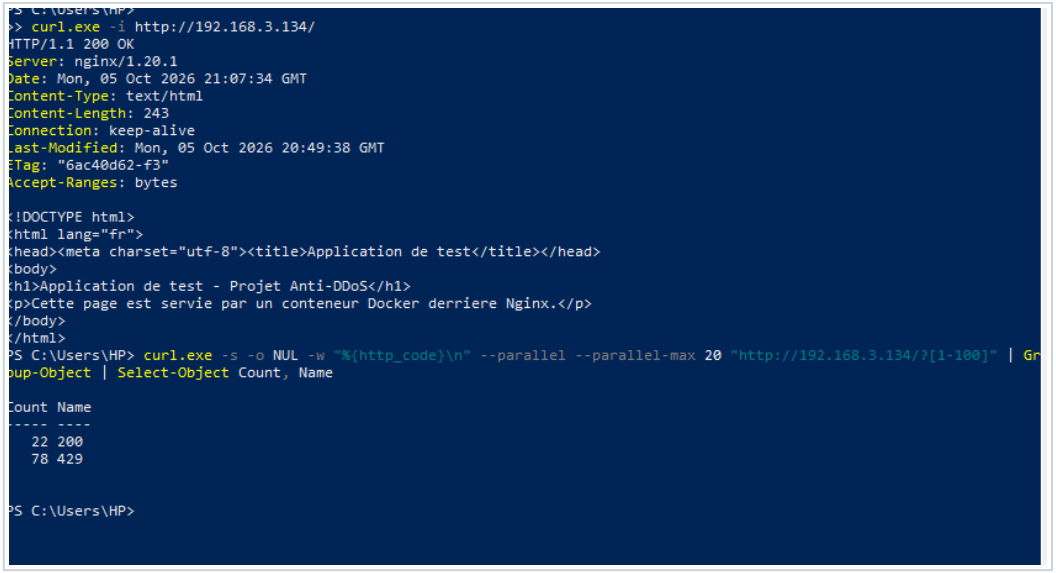
- Client → pare-feu → Nginx → application
- Application Docker publiée sur 127.0.0.1:8080 uniquement
- CrowdSec lit les journaux Nginx ; le bouncer bloque dans nftables
- Supervision et API en local ; Grafana par tunnel SSH
- VM RHEL 9.8 (clone de ma VM de certification)

Hardening de l’hôte : avant / après

Mesure	Avant	Après
SSH : connexion root	autorisée	refusée
SSH : mot de passe	accepté	clé uniquement
SSH : essais maximum	6	3
SSH : utilisateurs	tous	rayen seulement
Pare-feu	cockpit, dhcpv6, ssh (tous)	http, https ; ssh depuis 192.168.3.1
Noyau	—	SYN cookies, backlog 4096

SELinux Enforcing · bannière d’avertissement · sudo journalisé · AIDE : 191 856 fichiers surveillés

Nginx : trop de requêtes, 429



Rafale de 100 requêtes depuis le client : 22 × 200, 78 × 429

- 10 requêtes/s par IP, burst 20, 20 connexions max.
- Excès rejeté en 429 avant d'atteindre l'application
- Backend injoignable depuis le client (timeout sur :8080)
- Chaque rejet est écrit dans error.log, lu par CrowdSec

CrowdSec : de l'alerte au blocage

```
[rayen@anti-ddos-gateway webapp]# sudo cscli alerts list
[sudo] Mot de passe de rayen :
```

ID	value	reason	country	as	decisions	created_at	kind
7	Ip:192.168.3.1	crowdsecurity/nginx-req-limit-exceeded			ban:1	2026-10-10T14:23:49Z	crowdsec
6	Ip:192.168.3.1	crowdsecurity/nginx-req-limit-exceeded			ban:1	2026-10-10T13:14:36Z	crowdsec
4	Ip:192.168.3.1	crowdsecurity/nginx-req-limit-exceeded			ban:1	2026-10-06T14:17:51Z	crowdsec
2	Ip:192.168.3.1	crowdsecurity/nginx-req-limit-exceeded			ban:1	2026-10-06T12:13:51Z	crowdsec

```
[rayen@anti-ddos-gateway webapp]# sudo cscli decisions list
```

ID	Source	Scope:Value	Reason	Action	Country	AS	Events	expiration	Alert ID
45004	crowdsec	Ip:192.168.3.1	crowdsecurity/nginx-req-limit-exceeded	ban			6	43s	7

```
[rayen@anti-ddos-gateway webapp]#
```

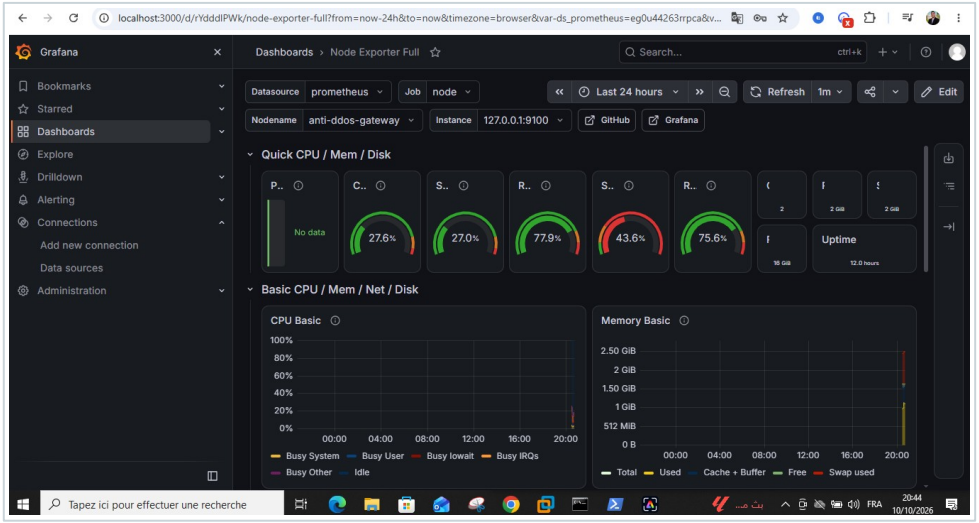
Alerte nginx-req-limit-exceeded sur 192.168.3.1 et décision « ban »

```
PS C:\Users\HP> 1..30 | ForEach-Object { Get-Date -Format "HH:mm:ss"; curl.exe -m 3 -s -o NUL -w "%{http_code}`n" http://192.168.3.134/health; Start-Sleep -Seconds 5 }
17:09:17
200
17:09:22
000
17:09:30
000
17:09:38
000
17:09:47
000
17:09:55
000
17:10:03
000
```

200 à 17:09:17, puis timeout dès 17:09:22

- Détection réelle déclenchée par la rafale, pas un ban manuel
- Le bouncer nftables rejette les paquets avant Nginx
- Ban de 2 min en laboratoire (4 h par défaut)

Grafana et OpenSCAP



Grafana : CPU, mémoire, réseau de l'hôte

Scan OpenSCAP (CIS niveau 1)	Initial	Final
Conformes	157	167
En échec	118	108
Non applicables	20	20

- OpenSCAP compare la VM à un référentiel reconnu : preuve d'audit avant/après
- Écarts restants classés : acceptés, reportés ou à traiter

Bilan : objectifs et résultats

Objectif	Statut	Preuve
Hôte RHEL durci (modèle)	**Atteint**	sshd -T, pare-feu, AIDE ; RHEL 9.8 au lieu de 10
Conteneurisation Docker + Compose	**Atteint**	Application sur 127.0.0.1:8080
Reverse proxy et limitation du débit	**Atteint**	22 × 200 et 78 × 429
Détection et blocage automatiques	**Atteint**	Alerte, ban, timeout du client
Supervision	**Atteint**	Prometheus, Node Exporter, Grafana
Conformité et preuves d'audit	**Partiel**	167 règles CIS conformes sur 275
DDoS volumétrique	**Non couvert**	Protection en amont nécessaire

Limites et recommandations

Limites assumées

- Un DDoS volumétrique saturant le lien n’est pas arrêté par une VM locale
- Rafales depuis une seule IP ; RHEL 9.8 au lieu de 10
- 60,7 % de règles conformes : écarts restants documentés

Pour la production

- Protection en amont : FAI, CDN/WAF, scrubbing
- HTTPS, WAF applicatif, seuils réglés sur le trafic réel
- Alertes, procédure d’incident, haute disponibilité

CONCLUSION

Ce qu’il faut retenir

Réalisé

Une architecture durcie : point d’entrée unique, limitation de débit, détection et blocage automatiques, supervision, preuves d’audit.

Mesuré

22 réponses 200 et 78 réponses 429 sur 100 requêtes ; blocage effectif en quelques secondes ; 157 à 167 règles CIS conformes.

Retenu

La défense en profondeur réduit l’impact et fournit des preuves, mais ne remplace pas une protection en amont.

Merci pour votre attention

Questions ?

Rayen Sliti · Encadrant : Mourad Melliti · TEK-UP University